Ex1 Day 2: keep-on-track sheet

Repo: **github.com/lwild12/EPA**, folder **`ex1-design/`**. Full detail is in **`build_guide_and_day2_plan.md`**. This sheet only keeps you on time.

Rules

1. 15 minutes over a box? Stop. Move on. Come back at the end.
2. Screenshot evidence straight after each task.
3. No new network changes after task 2 unless a test fails.
4. Never cut: some evidence for all 8 topics, and the justification.

Schedule (6 hours)

#	Task	Mins	Clock	Done
1	Read pass/merit/distinction. List the 8 topics.	10	____	☐
2	Part A on the real file, then test table	60	____	☐
3	Prototype + attacks (topics 2, 4)	75	____	☐
	Break	10	____	☐
4	OS hardening (topic 3)	40	____	☐
5	TLS + keys (topic 5)	25	____	☐
6	Security case (topic 6)	25	____	☐
7	Architecture (topic 7)	25	____	☐
8	Policy + legal (topic 8)	25	____	☐
	Break	10	____	☐
9	Justification, 900 to 1,100 words	50	____	☐

1. Read the sheet (10)

☐ Write the 8 topics as a checklist
☐ Note what each grade needs

2. Part A rebuild (60)

Order matters. Step 1 first, so you cannot lock yourself out.

☐ 1 Secure management: SSH, local login (router)
☐ 2 Router address on VLAN 1001, shut spare port

☐ 3 Switch: management to VLAN 1001, trunk, tidy
☐ 4 Fix the NAT access list (six permit lines)
☐ 5 Server0: DNS record, DHCP pools
☐ 6 Cloud care server on ISP side, HTTPS only
☐ 7 Admin PC, two APs, wireless clients, baseline tests
☐ 8 ACLs: clinical, devices VLAN, router SSH
☐ 9 Test table, before and after ACLs
☐ 10 Save configs, screenshot, record the design

Stuck? Guide, Part A, same step number.

3. Prototype and attacks (75)

☐ **Spec table (10):** inputs, outputs, functions, security needs, constraints
☐ **Build v1 (25):** `prototype/sync.php`, `schema.sql`, `make_token.php`
☐ **Test (10):** `bash test_sync.sh`, paste the actual codes
☐ **Attack (20):** Burp Repeater, one SQLMap run, oversized body, wrong type
☐ **Fix and retest (10):** same tests, others still pass

Only your own machine. Note you have authority. Nothing found? Say so, list what you tried. PHP unclear: the guide appendix "`sync.php` explained".

4. OS hardening (40)

☐ VM snapshot first (5)
☐ "Before" commands saved to a file (10)
☐ Threat to setting to check table (10)
☐ Apply: Security Compliance Toolkit baseline, LGPO (10)
☐ Re-run the commands, save "after" (5)

Target: Windows 11 clinical laptop, standard user, offline use.

5. TLS and keys (25)

☐ What needs encrypting (5)
☐ Capture HTTP then HTTPS in Wireshark (10)
☐ OpenSSL cert, XAMPP `httpd-ssl.conf` (see guide)
☐ Set `REQUIRE_HTTPS` to `true` in `sync.php`, retest
☐ Key lifecycle table (5) and revocation proof

6. Security case (25)

☐ Define the case: what, from whom, why, what if (10)

☐ Risk table, scored (10)

☐ Trade-offs: security against usability (5)

7. Architecture (25)

☐ Diagram with trust boundaries (15)

☐ Principles applied (5)

☐ Attacker's path, then justify big decisions (5)

8. Policy and legal (25)

☐ List requirements (10): UK GDPR (72-hour ICO report), DSPT, Caldicott, Computer Misuse Act

☐ Four short policies (15)

☐ Map each rule to a control and evidence

☐ Name the gaps

Quote the regulator's own words, not summaries.

9. Justification (50)

Section	Words
Context and problem	100
Network design	200
Prototype and findings	150
OS and key management	150
Case, architecture, trade-offs	150
Policy and legal	100
Limits and residual risk	100

☐ First person, reasons tied to the brief

☐ One thing you rejected, and why

☐ Say what the simulator cannot show (HTTPS simulated, DNS cannot forward, self-signed cert)

☐ Cite evidence by name, such as "test table row 7"

☐ Word count in Word: 900 to 1,100

Behind? Cut in this order

1. Part A extras: login block, banner, port security
2. Test rows 8 and 9, and extra attacks beyond Burp Repeater and one SQLMap run
3. Two policies in full, outline the other two
4. Shorten OS "before" to firewall, encryption, accounts
5. Never cut the 8-topic evidence or the justification